

DEREXI: POLICY PILOT

Code Analysis & Security Testing

Static Analysis • Reliability • Maintainability • Accessibility

OBJECTIVE

This report documents a security-focused review of DeRexi using SonarQube for IDE and targeted runtime testing. The analysis identifies code-quality weaknesses, verifies expected application behavior, and records remediation opportunities before release.

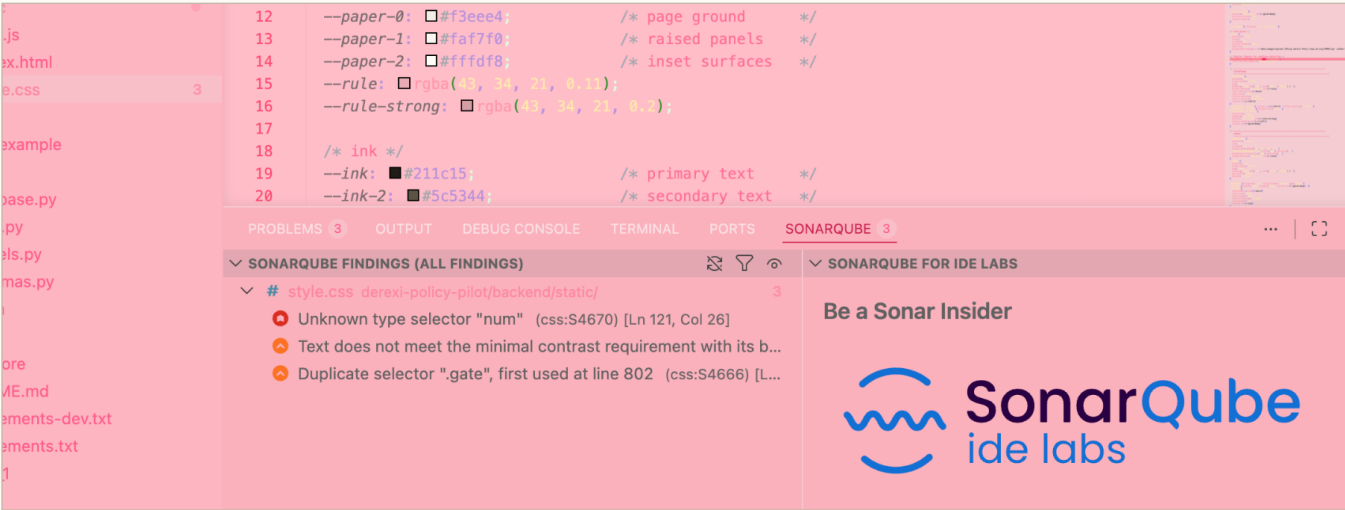


Figure 1. SonarQube for IDE surfaced three CSS findings during static code review.

STATIC ANALYSIS FINDINGS

01 Unknown selector HTML, SVG, and MathML define the selectors which can be used in a CSS. A selector that is not part of them is likely to be a typo or a misunderstanding of the CSS syntax. Noncompliant code example <pre>field {}</pre> Reliability finding: an unknown type selector ("num") was identified near line 121, suggesting a typo or misunderstood CSS selector.	02 Low contrast More Info Color contrast is essential for web accessibility. When text doesn't have enough contrast against its background, it becomes difficult or impossible for users to read. Users with visual impairments, including color blindness, low Accessibility / maintainability finding: text and background colors did not meet the minimum contrast requirement.	03 Duplicate selector Why is this an issue? How can I fix it? More Info In CSS, when selectors are duplicated, the browser applies them Maintainability finding: the .gate selector is duplicated, which can create unexpected cascade behavior and harder debugging.
--	--	---

RUNTIME VALIDATION

Policy Assistant Test Cases

TEST 1 — VALID POLICY QUESTION | PASS

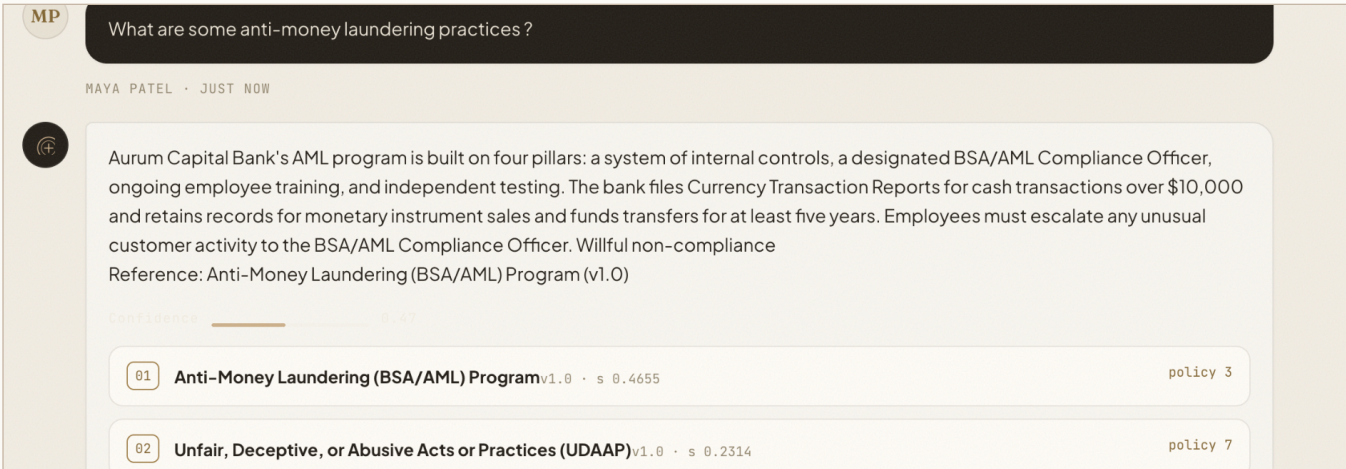
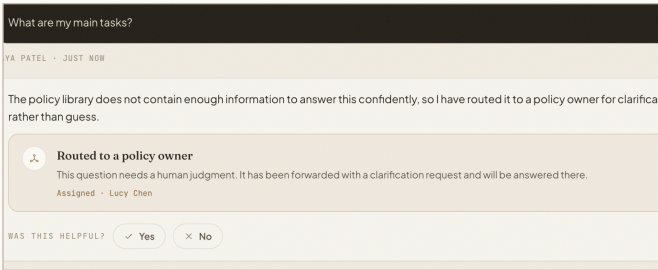


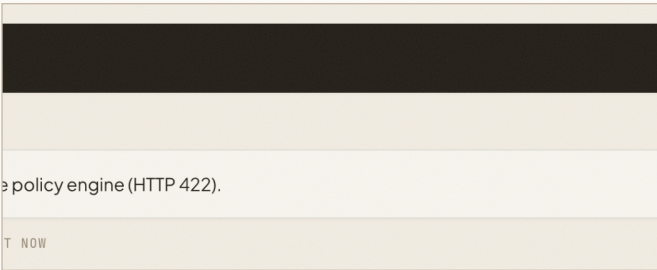
Figure 2. Grounded AML answer with policy reference, related results, and a visible confidence score.

TEST 2 — UNSUPPORTED QUESTION | PASS



“What are my main tasks?” was not supported by the policy library. DeRexi declined to guess and routed the question for human clarification.

TEST 3 — MALFORMED INPUT | PARTIAL PASS



A single slash (/) was rejected with HTTP 422. Invalid data was not processed, but the user-facing message exposes a technical backend error.

SECURITY TEST SUMMARY

Valid policy question	Grounded answer + cited policy	PASS
Unsupported / unclear question	Declines to guess + routes for clarification	PASS
Malformed input	Backend rejects request; UX validation needs improvement	PARTIAL PASS

Remediation priorities

Correct the unknown selector, consolidate the duplicate .gate rule, improve the flagged color contrast, and add client-side input validation so malformed questions receive a clear prompt instead of an HTTP 422 error.